

Folios — Security

FOLIOS · FOLIOSHQ.COM

LAST UPDATED: 2026-05-30

This document describes Folios's security posture: the controls in place, the sub-processors involved, and where Folios stands on common enterprise security questions.

For specific data-handling and AI-data-flow questions, see [data-handling.md](#).

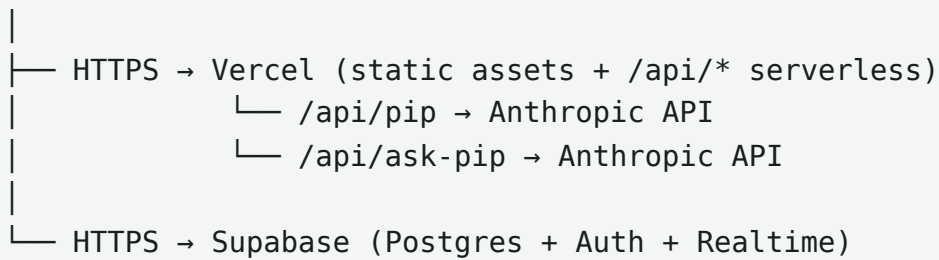
At a glance

Control	Status
Authentication	Supabase Auth (email/password)
MFA / 2FA	Supported via Supabase TOTP (enable in Dashboard)
Encryption in transit	TLS 1.3 (all endpoints)
Encryption at rest	AES-256 (Supabase managed)
Row-Level Security	Enforced on every user-data table via <code>auth.uid()</code>
Session timeout	60 minutes of inactivity → auto-logout
Password strength	8+ chars, uppercase, number required
Rate limiting	20 Pip API calls / minute / user
Audit log	Per-user activity feed (folio_activity)
Error observability	Per-user error log (folio_errors) with retention controls
Sub-processor SOC2	Supabase  · Vercel  · Anthropic 
Data residency	US (Supabase US region)
Data export	Per-account JSON export available
Account deletion	User-controlled; cascade enforced via RLS

Architecture

Folios is a single-page React PWA hosted on Vercel, talking to a Supabase Postgres backend. AI features call the Anthropic API via a Vercel serverless proxy. There is no separate backend server we operate — security boundaries are the three managed services and the user's browser.

Browser (PWA)



All three sub-processors are SOC 2 Type 2 attested.

Authentication & authorization

Identity

- Email/password accounts via Supabase Auth.
- Passwords are bcrypt-hashed by Supabase (never visible to Folios).
- Optional TOTP-based MFA (Supabase native — toggle in Auth settings).
- Email verification can be enforced (Supabase Auth setting).

Sessions

- JWT-based sessions issued by Supabase.
- 60-minute inactivity timeout enforced client-side in `useAuth.js` ; Supabase enforces token refresh independently.
- Logout clears local storage and Supabase session.

Authorization

- Every user-data table has **Row Level Security (RLS)** policies scoped to `auth.uid()` . The database refuses to return rows that don't belong to the requesting user.

- No service-role keys are ever used from client code. Server-side routes (`/api/pip`) verify the user's bearer token before making Anthropic calls.
 - Organization (multi-tenant) support is built in: `folio_org_members` controls who sees what within a shared org. Role values: `owner` | `admin` | `member` . Owner can invite, revoke, manage settings.
-
-

Data protection

In transit

- TLS 1.3 on every connection (Vercel, Supabase, Anthropic).
- HSTS enforced on `folioshq.com` .
- The PWA service worker only caches static assets and shell HTML. Personal data is not cached offline beyond a localStorage backup of active notes (used for autosave-failure recovery).

At rest

- Supabase manages encryption at rest using AES-256 on its underlying cloud storage.
- Backups are taken daily by Supabase and retained per their managed service policy. (Point-in-time recovery is available on Pro tier.)

Secrets

- The Anthropic API key lives only as a Vercel environment variable (`ANTHROPIC_API_KEY`). Never embedded in client code.
 - The Supabase anon (publishable) key is shipped to the client by design — it's a public key whose scope is strictly limited by RLS.
-

Application-level controls

Rate limiting

- Pip API: **20 requests per minute per user**, enforced in `/api/pip` via in-memory counter (resets per serverless instance).
- This prevents both runaway client loops and intentional abuse.

Cost controls

- Per-user Pip API usage tracked in `folio_pip_usage` (tokens, mode, timestamp). Visible to the user in Settings → Pip Usage.
- Stacked prompt caching (4 cache breakpoints) reduces redundant context costs by ~70% on multi-call sessions.
- Trivial-draft short-circuit: drafts under 100 characters never call the API at all.

Input validation

- All structured fields are validated client-side and re-validated by RLS-aware Supabase mutations.
- Pip prompt-injection guards: user-supplied text is sandwiched between system instructions that refuse instruction-override attempts.

Output handling

- AI-generated text rendered through a markdown renderer that strips arbitrary HTML.
- No `eval` or `dangerouslySetInnerHTML` in the codebase.

Audit log

- Every write operation (account/meeting/item create/update/delete) fires a `logActivity(...)` call into `folio_activity`.
- Owner-role users can see org-wide activity in Settings → Activity.
- Non-owner users see their own actions only.

Observability

- Client-side errors captured to `folio_errors` (RLS-scoped per user).
 - React errors, network failures, Pip errors, unhandled rejections all logged with stack and context.
 - Visible in Diagnostics view (Settings → Diagnostics).
 - Auto-recovery for stale-chunk Lazy import failures (post-deploy edge case) handled silently and marked auto-resolved.
-
-

Vulnerability management

Dependencies

- All production dependencies pulled from npm with package-lock.json pinning.
- Critical: `@supabase/supabase-js`, `react`, `vite`, `@anthropic-ai/sdk` (server-side only, in `api/pip.js`).
- GitHub Dependabot enabled on the repo for automated dependency alerts.

Infrastructure patching

- All three sub-processors (Supabase, Vercel, Anthropic) are responsible for their own infrastructure patching and incident response. SOC 2 Type 2 attestations

cover their patch management, vulnerability scanning, and incident response programs.

Code review

- All changes flow through git, pushed to a single deploy branch (`claude/build-folio-desktop-app-XzvZ5`).
- Single-developer pilot today; multi-reviewer process to be added before team rollout.

Sub-processors

Vendor	Role	SOC 2	Data residency
Supabase	Postgres + Auth + Realtime + Storage	Type 2	US
Vercel	Static hosting + serverless functions	Type 2	US (Vercel's edge network)
Anthropic	AI inference (Pip)	Type 2	US

No other vendors process Folios user data.

Incident response

Detection

- Client-side errors land in `folio_errors` , surfaced in the Diagnostics nav badge.

- Supabase and Vercel both provide status pages and email-alert integrations.
- No automated PagerDuty/Opsgenie tier today (single-user pilot); alerting will be added before multi-user rollout.

Containment

- Compromised user session: user can sign out (clears tokens server- and client-side); RLS prevents data leakage to other users regardless.
- Compromised Anthropic key: rotate via Vercel env var; old key becomes inert immediately.

Recovery

- Supabase point-in-time recovery (Pro tier) provides RPO < 5 minutes.
- Folios autosaves user notes/drafts to localStorage as a belt-and- suspenders backup against autosave network failures.

Notification

- For multi-user rollout, a documented user-notification flow will be added (e.g. email-to-all-users template + status page).

Privacy

What's collected

See [data-handling.md](#) for the complete data inventory.

Briefly:

- User-supplied: account names, meeting notes, contact info, custom fields the user chooses to add.

- Auth: email, hashed password, last sign-in (Supabase Auth).
- Usage: per-call Pip token usage, error logs, activity audit trail.

What's not collected

- No advertising trackers, analytics SDKs, or third-party scripts.
- No location data beyond manual lat/lng on MSO addresses entered by the user.
- No keystroke logging, screen recording, or session replay.

User controls

- Per-account JSON export (Account → Export).
 - Account deletion (cascades through all related data via RLS).
 - Inactive flag (soft archive — reversible; data preserved but excluded from active surfaces).
-

Compliance posture

Folios is not currently SOC 2, ISO 27001, or HIPAA attested as a `SERVICE`. The

underlying infrastructure (Supabase, Vercel, Anthropic) is SOC 2 Type 2, which covers the platform layer.

For enterprise customer deployments, a service-level SOC 2 audit would be the natural next step. This is not yet warranted given single-user pilot status.

GDPR posture: Folios stores no EU personal data today. If/when EU users join, a DPA with Supabase (already SCC-compliant) covers the sub-processor relationship; Folios's own DPA would be drafted as part of EU expansion.

Open questions / known gaps

These are not security failures — they're scope choices for a single-user pilot. Listed for transparency and to inform the multi-user readiness checklist:

- **Active session management UI** — not yet built. User can sign out on a single browser; revoking sessions across all devices requires Supabase Dashboard access today.
 - **PagerDuty / on-call alerting** — not in place. Manual monitoring.
 - **Penetration test** — not yet performed. Will be commissioned before paid customer deployment.
 - **Multi-reviewer code-review process** — single-developer pilot.
-
-

Contact

For security questions or to report a vulnerability: chris.vasconcellos97@gmail.com